

Project Analysis Report

DOLMIX — Restaurant Menu & Admin Panel

Report date: May 12, 2026

This report analyzes the DOLMIX restaurant ordering app — a React + Vite Arabic RTL frontend backed by an Express + PostgreSQL + Drizzle ORM API and an Arabic admin panel. It reviews the current state, strengths, and the issues found, ordered by severity. No source files were modified to produce this report.

Architecture overview

- pnpm workspaces monorepo with TypeScript 5.9.
- Frontend: artifacts/dolmax-menu (React + Vite) — Arabic RTL menu with cart and WhatsApp checkout.
- Backend: artifacts/api-server (Express 5 + memorystore) — exposes /api/menu, /api/admin/*, /api/auth/*, /api/storage/.*
- Database: PostgreSQL via Drizzle ORM (lib/db) with tables: categories, items, sizes, piece_options, settings.
- Admin panel mounted at /admin inside the same React app, sub-routed via wouter.
- Image storage: Replit Object Storage via presigned upload URLs.

Strengths

- TypeScript checks pass cleanly across all packages.
- Clear contracts via zod and drizzle-zod for request/response validation.
- react-query with cache invalidation propagates admin edits to the public menu instantly.
- All /api/admin/* routes are gated by a single requireAdmin middleware.
- Auto-seed on first boot when the DB is empty.
- Mobile-first design with iOS safe-area handling and solid RTL care.
- Production startup guard already refuses to boot without ADMIN_PASS / SESSION_SECRET set.

Critical issues

CRITICAL

1) API server fails to start due to port collision

Recent workflow logs show: EADDRINUSE: address already in use :::8080. A previous server process is still bound to port 8080, so the new instance cannot start. As a result, both the admin panel and the public menu are non-functional right now (the public menu is API-driven via /api/menu). This is an environmental issue, not a code defect — restarting the API Server workflow after ensuring the old process has exited resolves it.

File: Workflow: artifacts/api-server: API Server

CRITICAL (security)

2) Private object reads have no access control

GET /api/storage/objects/* serves any file from the private object directory (PRIVATE_OBJECT_DIR) with no ACL check. If an object path leaks (logs, old responses, or guessed paths), anyone can download the asset. All admin-uploaded images go through this path. Since menu images are intentionally public, the safest fix is to either move them to a public bucket explicitly, or wire in the existing objectAcl.ts helpers to enforce a public-read ACL per object.

File: artifacts/api-server/src/routes/storage.ts (line 56)

CRITICAL (security)

3) Default admin password and session secret in source

auth.ts: ADMIN_PASS = process.env.ADMIN_PASS || "dolmix2026". app.ts: SESSION_SECRET = process.env.SESSION_SECRET || "dolmix-dev-secret-change-me". The startup guard in index.ts correctly refuses to boot in production if these are unset, which is the right safety net. Still, the defaults must be overridden before publishing, and the admin password must be rotated for any real deployment.

File: artifacts/api-server/src/{app.ts, routes/auth.ts}

High-severity issues

HIGH

4) Sessions stored in memory (memorystore)

Sessions live in process memory. Every server restart logs every admin out, and horizontal scaling (multiple replicas behind a load balancer) is not supported. For production, switch to a durable store such as connect-pg-simple backed by the existing PostgreSQL.

File: `artifacts/api-server/src/app.ts` (line 39)

HIGH

5) Reorder endpoints run sequential UPDATES without a transaction

Each `/reorder` route loops over `orderedIds` and issues one `UPDATE` per row. If any update fails midway, `displayOrder` is left in an inconsistent state. Wrap the loop in `db.transaction(...)` for atomicity. A single `CASE WHEN` statement would also be markedly faster.

File: `artifacts/api-server/src/routes/admin.ts` (lines 87-99, 186-198, 245-257)

HIGH

6) Item reordering logic is incorrect when a category filter is active

`ItemsPage.tsx` — `move()` builds the new ordered list with a ternary that swaps two ids in their original positions inside the full list, but ignores the visual position of the filtered list. With items from multiple categories interleaved this can produce surprising orderings. The correct approach is to swap inside the filtered list, then merge that ordering back into the full list while preserving the positions of unfiltered items.

File: `artifacts/dolmax-menu/src/admin/ItemsPage.tsx` (lines 50-61)

HIGH

7) Auto-generated category slug uses an unreadable timestamp

If the slug field is left empty, the client generates ``cat-<timestamp>``. The server validation regex (`^[a-z0-9_-]+$`) accepts it, so the request succeeds. The result is technically valid but UX-hostile: categories end up with names like `cat-1715539200000` in URLs/exports, and there is no easy way to rename slugs later. Generate from the Arabic name (transliteration or a stable hash) or require a slug explicitly.

File: `artifacts/dolmax-menu/src/admin/CategoriesPage.tsx` (line 24)

HIGH

8) Rolling sessions can extend admin sessions indefinitely

rolling: true refreshes the cookie on every request. An admin who keeps any tab open effectively never expires, which contradicts the intent of maxAge. Reconsider per security policy — typical practice is to use a shorter absolute lifetime in addition to the sliding window.

File: artifacts/api-server/src/app.ts (line 38)

HIGH

9) Public menu fetched with credentials: include

useMenu.ts always sends cookies on /api/menu even though the public menu requires no authentication. There is no direct vulnerability, but it prevents easy CDN/proxy caching and complicates any future cross-origin deployment.

File: artifacts/dolmax-menu/src/hooks/useMenu.ts (line 16)

Medium-severity issues

MEDIUM

10) No CSRF protection on /api/admin/*

Auth is cookie-based with sameSite=lax. Lax blocks most cross-site POSTs but not all (e.g., top-level form submissions). For an admin surface this is worth hardening with a CSRF token, or at minimum an Origin/Referer check on state-changing routes.

File: artifacts/api-server/src/middlewares/auth.ts + admin.ts

MEDIUM

11) No upper bound on uploaded image size

RequestUploadUrlBody accepts any non-negative size. A compromised admin account (or an honest one) can issue presigned URLs for arbitrarily large objects, draining storage quota. Cap the size (for example, 5 MB per image) and reject content-types outside image/*.

File: artifacts/api-server/src/routes/storage.ts (line 10)

MEDIUM

12) ImageInput accepts any pasted string as a URL

The "or paste image URL" field stores the raw text. There is no check that it is a valid URL or that it points to an image, which can produce broken images on the public menu. Add minimal validation (e.g., /^https?:\w+/) and a preview before saving.

File: artifacts/dolmax-menu/src/admin/ImageInput.tsx (lines 74-80)

MEDIUM

13) New items have no legacyId, breaking stable references

ItemBody on the server omits legacyId, so items created from the admin panel get a generated `item-` identifier. This is fine for most uses but means hard-coded references in the frontend (Featured cards depend on legacy ids m2 and g2) cannot point to admin-created items.

File: artifacts/api-server/src/routes/admin.ts (line 134)

MEDIUM**14) Featured section depends on hard-coded legacy ids**

App.tsx (lines 100-103) builds the featured list as [m2, g2]. If those items are deleted in the admin panel, the section silently disappears, and there is no way for the admin to choose featured items. Add an isFeatured boolean to items, surface it from /api/menu, and expose a toggle in the admin panel.

File: artifacts/dolmax-menu/src/App.tsx (line 100)

MEDIUM**15) Cart does not reconcile against the live menu**

The cart persists in localStorage. If an admin deletes or hides an item that already sits in a customer's cart, the customer can still complete a WhatsApp order with the stale name and price. On menu load, drop or update cart entries whose itemId is no longer visible.

File: artifacts/dolmax-menu/src/hooks/useCart.ts (behavior, not specifically reviewed)

MEDIUM**16) Drizzle errors are blanket-mapped to a misleading message**

POST /admin/categories wraps the insert in try/catch and always returns "slug already exists" on any failure (network blip, unrelated constraint, etc.). Inspect the error code (unique_violation) and only return the friendly message in that specific case.

File: artifacts/api-server/src/routes/admin.ts (lines 44-57)

Low-severity notes

- MenuItem type is duplicated between data/menuData.ts (frontend) and routes/menu.ts (backend). Move the shared shape into a lib/* package.
- SECTION_IDS in App.tsx is hard-coded; categories created from the admin panel will not participate in scroll-spy.
- ImagesPage.tsx was not deeply reviewed in this report — it is largely a thinner variant of ItemsPage focused on swapping images.
- Delete confirmations rely on browser confirm/alert. A custom Dialog would be a friendlier UX.
- Two routes (/admin and /admin/:rest*) exist in App.tsx for the same component — works but inelegant; one wildcard is enough.
- No automated tests (unit or e2e) for either the API or the admin panel.
- Logger uses pino; verified no stray console.log in server code at present.

Summary & recommendations

Overall the project is well-organized and meets the stated goal: a database-backed menu editable from an Arabic admin panel. Type checks pass, basic auth is in place, and admin edits propagate to the public menu via cache invalidation. The most pressing items are operational (port collision blocking the API right now) and security hardening (object ACLs, secret rotation, CSRF).

Suggested order of remediation:

- Restart the API Server workflow to clear the current port collision (no code change required).
- Set ADMIN_PASS and SESSION_SECRET before publishing to production.
- Add an ACL check on /api/storage/objects/* or move menu images to a public bucket.
- Replace memorystore with connect-pg-simple for durable, multi-replica sessions.
- Fix the filtered-reorder logic in ItemsPage and wrap all /reorder loops in a transaction.
- Cap upload size and validate pasted image URLs.
- Add CSRF protection (token or Origin check) to admin state-changing routes.
- Reconcile the cart against the live menu on load to avoid stale prices in WhatsApp orders.

No project files were modified while preparing this report, as requested.

